

HTB / TryHackMe — Blog (Medium)

Plataforma: TryHackMe

Dificuldade: Medium

Status:  Em progresso

Autor: João Campbell

Data: 2026-05-01

Sumário

- 1. [Reconhecimento — NMAP](#)
- 2. [Enumeração Web — Gobuster](#)
- 3. [WordPress — WPScan](#)
- 4. [Credenciais Obtidas](#)
- 5. [Problema Encontrado](#)
- 6. [Próximos Passos](#)

1. Reconhecimento — NMAP

Comando utilizado

```
bash

nmap -v -A 10.129.145.181
```

Portas abertas

Porta	Protocolo	Serviço
22	TCP	SSH
80	TCP	HTTP
139	TCP	SMB
445	TCP	SMB

Observações do NMAP

- Sistema Operacional: **Linux** (Ubuntu)
- Samba: **4.7.6-Ubuntu**
- Nome do computador: **BLOG**
- FQDN: **blog**
- SMB com message signing **desabilitado** (potencialmente perigoso)
- Autenticação SMB via conta **guest** aceita

2. Enumeração Web — Gobuster

Comando utilizado

```
bash

gobuster dir -u http://10.129.145.181/ -w /usr/share/wordlists/seclists/Discovery/We
```

Diretórios / Endpoints encontrados

Path	Status	Observação
/	301	Raiz
/admin	302	Painel de administração (redirect)
/dashboard	302	Dashboard (redirect)
/wp-admin	301	Painel WordPress
/wp-content	301	Conteúdo WordPress
/wp-includes	301	Includes WordPress
/login	301	Redirect para wp-login.php
/robots.txt	200	Arquivo robots.txt presente
/xmlrpc.php	405	XML-RPC ativo

Nota: A presença do `xmlrpc.php` é relevante — será explorado na fase de ataque.

3. WordPress — WPScan

Identificação de usuários

Antes de executar o WPScan, foi feita uma enumeração manual dos autores do blog, identificando dois possíveis nomes de usuário:

- `kwheel`
- `billy`

Informações do WordPress

- **Versão:** 5.0 (Insecure — released 2018-12-06)
- **XML-RPC:** Habilitado (`http://10.129.145.181/xmlrpc.php`)
- **Servidor:** Apache 2.4.29 (Ubuntu)

Comando — Brute Force via XML-RPC

```
bash

wpscan --url http://10.129.145.181 -U kwheel -P /usr/share/wordlists/rockyou.txt
```

4. Credenciais Obtidas

Usuário	Senha	Método
<code>kwheel</code>	<code>cutiepie1</code>	XML-RPC bruteforce

Próximo passo esperado: utilizar essas credenciais para acessar o painel WordPress em `/wp-login.php` e tentar escalar para RCE (Remote Code Execution) via plugin ou editor de temas.

5. Problema Encontrado

Ao tentar efetuar login com as credenciais descobertas, o laboratório do TryHackMe apresentou instabilidade — o domínio `blog.thm` não estava resolvendo corretamente, impedindo a continuação do desafio.

Erro: `Server Not Found – Firefox can't connect to the server at blog.thm`

Possível causa: o servidor VPN/lab do TryHackMe foi reiniciado ou expirou durante a sessão.

6. Próximos Passos

Quando o lab estiver disponível novamente:

- ☐ Fazer login em `/wp-login.php` com `kwheel / cutiepie1`
 - ☐ Verificar nível de acesso (Author / Admin)
 - ☐ Explorar CVE relacionados ao WordPress 5.0 (ex: crop-image RCE)
 - ☐ Tentar upload de reverse shell via editor de temas ou plugin malicioso
 - ☐ Enumerar SMB com as credenciais obtidas
 - ☐ Capturar flags `user.txt` e `root.txt`
-

Referências

- [WPScan Docs](#)
- [WordPress 5.0 RCE — CVE-2019-8943](#)
- [XML-RPC Bruteforce](#)